Firewall Policy Complexity: From Simple ACLs to Least Privilege Network Access

BACSE203 Computer Networks · Fall 2026 · Case Study (Topic 17)

Ramsrivathsan R
25BCE2111

S Darshan
25BCE2883

M B Adavan
25BCE0063

Naveen V S
25BCE0059

Himaneesh S
25BAI0007

PERMIT DENY

School of Computer Science and Engineering, VIT Vellore

The problem we studied

Broad rules are easy, but open

Most small networks let every department reach every server. One router ACL can close those paths.

Strict rules are safe, but costly

Each step towards least privilege adds rules, conditions and dependence on rule order, which the literature links to configuration errors.

Research question

How does refining network access policy from broad, to department-level, to service-level least privilege change (a) the unnecessary flows the policy allows and (b) the policy's size, specificity and dependence on rule order, and how do these results compare with the literature?

SECURITY COST measured together, on one network

What the literature says (Part A)

1 Perimeter filtering

Default deny at the boundary; inside often trusted

[3], [6], [7]

2 Policy anomalies

First-match order causes shadowing and redundancy

[9]–[12]

3 Growth & misconfiguration

Real rule sets are often wrong; complexity tracks risk

[1], [2], [13]

4 Least privilege & Zero Trust

No trust from location; segment to limit lateral movement

[4], [5], [14]–[16]

5 Management tools

Detect or prevent anomalies; usability rarely tested

[10]–[13], [17]

Gaps we found, and our response

1. Empirical data on misconfiguration are dated and from few sources
2. Unnecessary access is rarely measured against written requirements
3. Security gain and management cost are seldom measured on the same policy
4. Management tools are seldom evaluated with real users

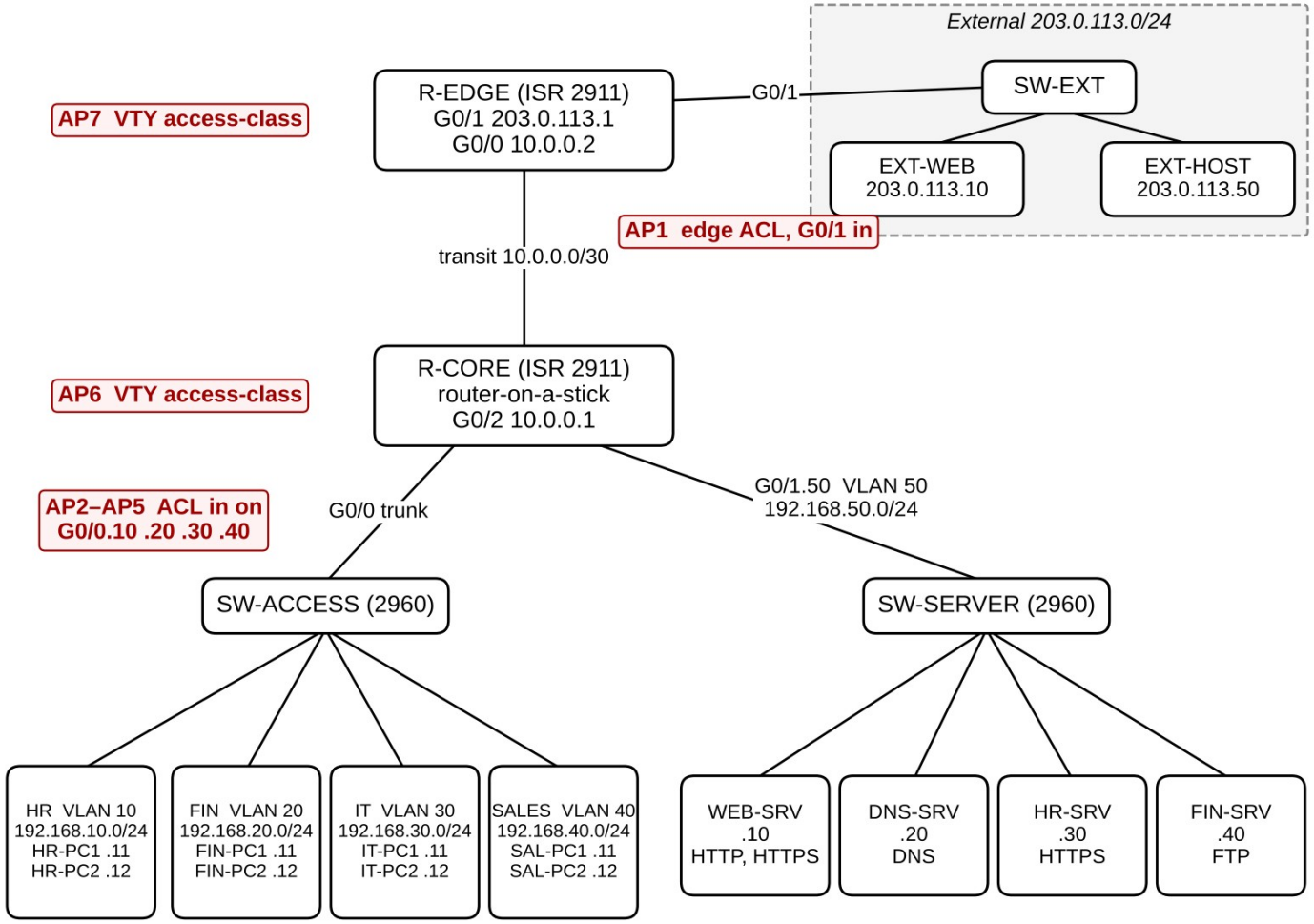
Our response to gap 3

Write required and forbidden flows first.

Apply three policies of increasing precision to one network.

Measure leakage and policy size at every stage.

Network design: 19 devices, 7 enforcement points



4 departments

HR, Finance, IT, Sales: VLANs 10–40

4 servers

Web, DNS, HR records (HTTPS), Finance (FTP)

Simulated Internet

203.0.113.0/24 (RFC 5737)

7 enforcement points

Edge ACL, 4 department ACLs, 2 router logins

Three policies of increasing precision

Stage 1

Broad

Any internal source → any destination; only the Internet edge filtered

10 rules

Stage 2

Department-level

Own department → whole server zone and Internet; other departments denied

25 rules

Stage 3

Least privilege

Each department → exact host, protocol and port it needs; SSH only for IT

40 rules

Stage 0 (no ACLs) is the positive control: every test must work before any rule is applied.

Test method

1

Write flows

8 required, 7 forbidden, 1 uncontrollable

2

Build Stage 0

All 17 tests must work

3

Apply stage

Paste ACLs on both routers

4

Run same 17 tests

Same PCs, same order

5

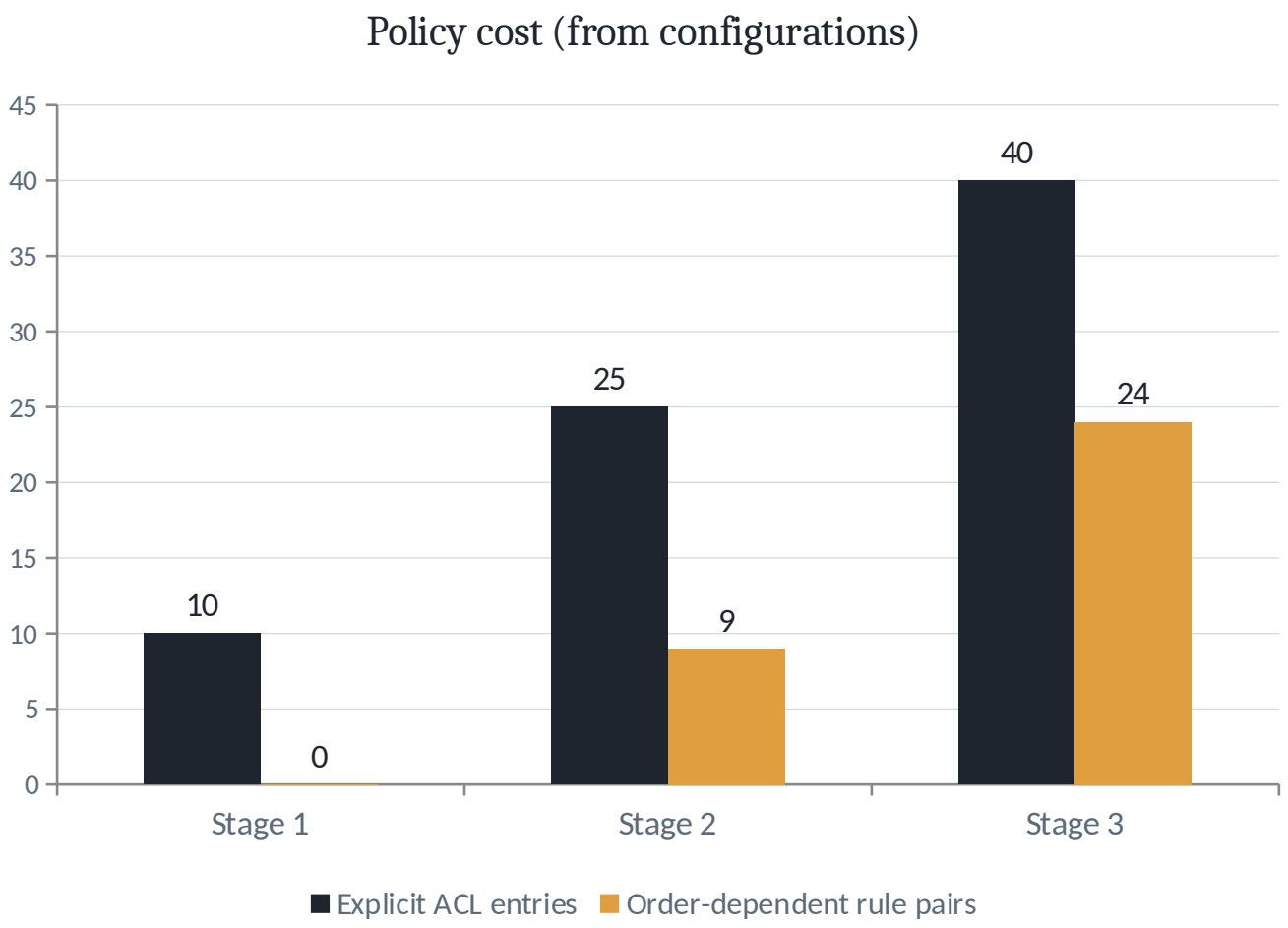
Record evidence

Screenshots and ACL counters

Metrics fixed before any result

- Leakage = forbidden tests that succeeded ÷ forbidden tests evidenced
- Required success = required tests that succeeded ÷ required tests evidenced
- Policy size, rule specificity and order-dependent rule pairs, from the configurations

Results: access fell as rules grew



Stage 1

2 of 2 forbidden flows worked

Stage 2

4 of 8 forbidden flows worked

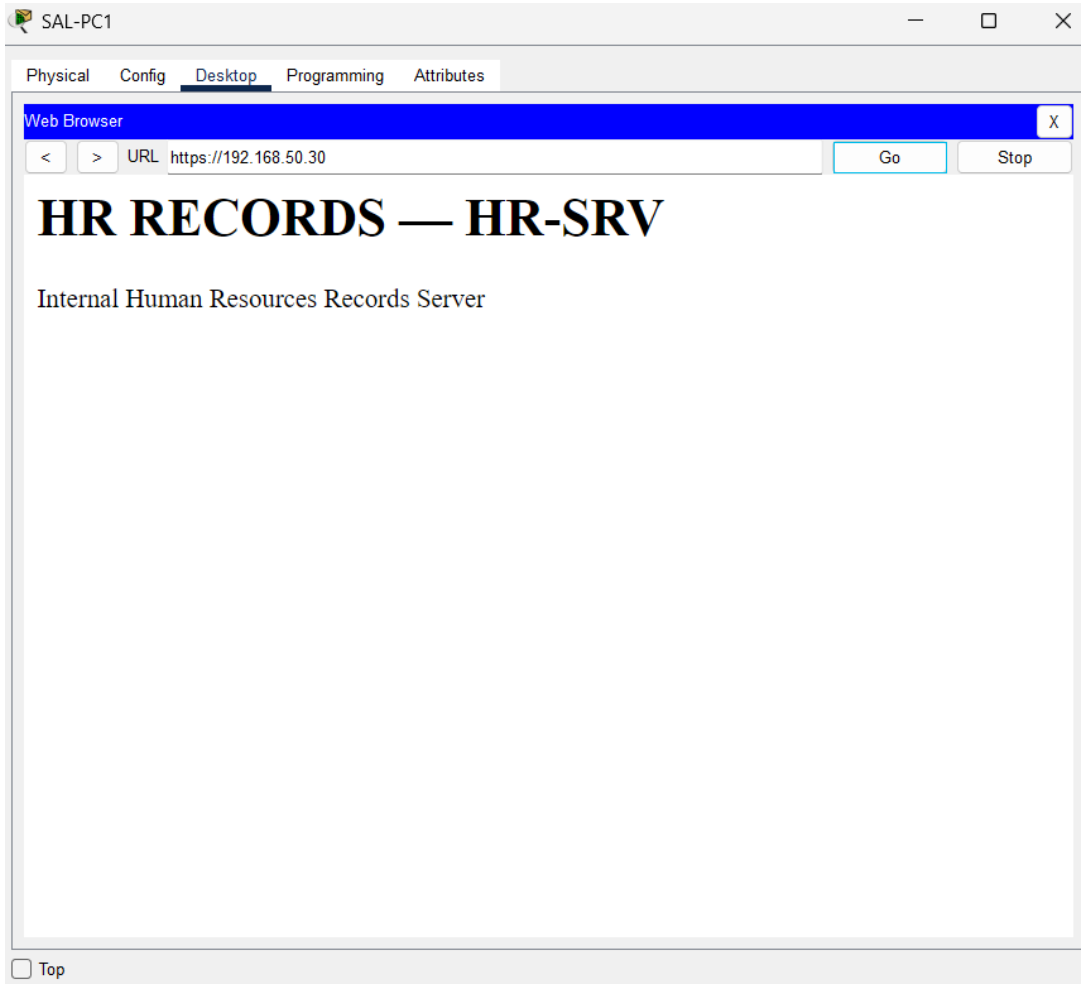
Stage 3

0 of 4 forbidden flows worked

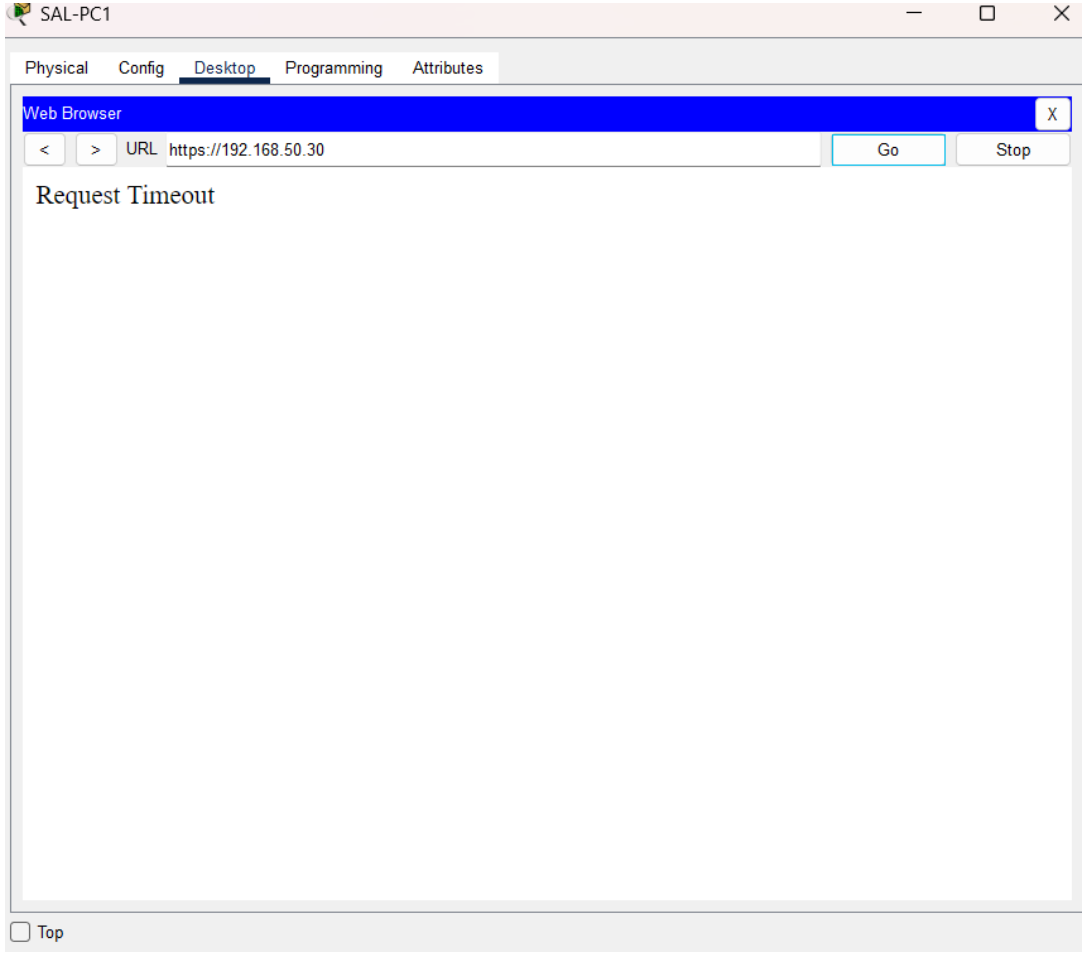
Counts cover only tests with screenshot evidence, so they are not compared as percentages.

Same test, two policies: Sales → HR records (T10)

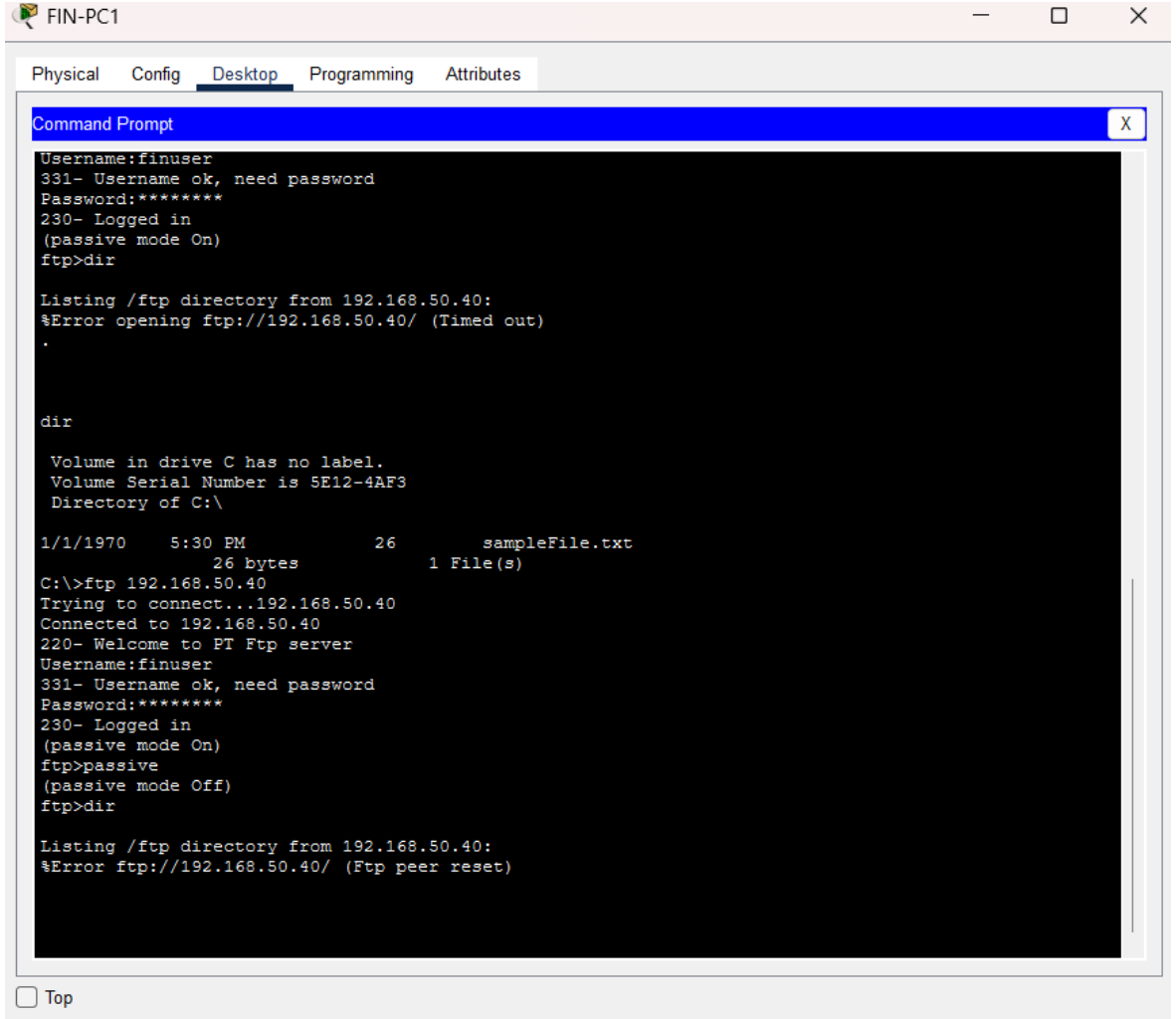
PERMIT **Stage 2: department rule opens the whole server zone**



DENY **Stage 3: only HR may reach HR-SRV on port 443**



Key finding: least privilege broke a required service



What happened

Finance could log in to its FTP server, but listing files failed: "Timed out" (passive) and "Ftp peer reset" (active).

Why

The Stage 3 rule permits only the FTP control port (21). FTP's separate data connection hits the "deny internal" rule.

So what

Least privilege costs more than rules: multi-connection services need extra, carefully ordered entries.

Other observations

Two locks, two symptoms

In Stage 2, Sales SSH to 192.168.40.1 timed out (interface ACL) while SSH to 192.168.50.1 was refused (router login rule): one goal, enforced in two places.

Rule count can mislead

The Stage 3 edge ACL is the strictest but has the fewest entries (6 → 6 → 5).

Same-VLAN traffic

HR-PC1 always reached HR-PC2: traffic inside a VLAN never passes the router, so no router ACL can filter it.

Build issues fixed

A duplicate IP on R-CORE and wrong server addresses were found in Stage 0 and corrected before testing.

How our results compare with the literature (Part C)

Observation	Literature	Relation
Forbidden flows: 2 of 2 → 4 of 8 → 0 of 4	[3], [5]	Agrees
Rules 10 → 25 → 40; order pairs 0 → 9 → 24	[2]	Agrees in direction
Strictest edge ACL has fewest entries	[9], [10]	Agrees: count misleads
Department rules still let Sales reach HR data	[4], [15]	Agrees: zone trust too coarse
Stage 3 broke FTP file listing	[13]	Partly: adds a concrete usability cost
Same-VLAN traffic never filtered	[15], [16]	Agrees: limit of router ACLs

We measured reachability and policy structure, not administrator error, so [2] is matched in direction, not proven.

Limitations

Small scale

19 devices and 40 rules, versus large real rule sets

Evidence gaps

Screenshots for 17 tests in Stage 0, 4 in Stage 1, 14 in Stage 2, 7 in Stage 3

Not Zero Trust

ACLs see addresses and ports, never user or device identity

Simulator models

FTP stands in for a database; no NAT, logging or attack traffic

Not run

Misconfiguration experiments M1 and M2; zero-hit and line-change metrics

Stateless filter

established accepts any TCP segment with ACK or RST set

Conclusion

Security improved

Forbidden access fell from broad to least privilege; all forbidden flows we captured were blocked in Stage 3

Cost rose

Rules grew 4× and order-dependent pairs from 0 to 24

Usability suffered

Least privilege broke FTP file listing until the policy is extended

Write the required flows first, then refine — the trade-off is real, and it can be measured.

Thank you · Questions?